

IAM Access Risk Audit Report

Prepared by: Senior IAM & GRC Security Auditor

Classification: Confidential – Internal Audit Use Only

Review Scope: Automated Access Review – User Account Risk Findings

Executive Summary

The following findings were identified during an automated Identity and Access Management (IAM) access review. Four (4) access risk conditions were detected spanning terminated user accounts, excessive privilege assignments, and dormant account activity. These findings represent material risks to the organization's information security posture, regulatory compliance obligations, and internal control environment. Immediate remediation is recommended for Critical and High severity findings. Each finding is documented below with supporting risk narrative, compliance framework mappings, and actionable remediation guidance.

Detailed Findings

FINDING: [CRITICAL] — mgarcia

RISK:

User account `mgarcia`, associated with the Finance department in the role of Analyst, has been identified as belonging to a terminated employee whose system record remains active within the identity management environment. The continued existence of an active account for a non-employed individual represents one of the most severe access control failures an organization can exhibit. Terminated users retain logical access pathways — including credentials, session tokens, and system entitlements — that may be exploited either by the former employee directly or by a malicious third party who obtains those credentials. The Finance department context amplifies this risk considerably, as active accounts in this area may permit unauthorized access to financial systems, general ledger data, payment processing workflows, or sensitive customer financial records. There is no legitimate business justification for a terminated user to maintain an active system presence under any circumstance.

IMPACT:

From a business perspective, this finding exposes the organization to the risk of unauthorized financial transactions, data exfiltration of sensitive records, or sabotage by a disgruntled former employee. The reputational and financial consequences of a breach originating from a ghost account are significant. From a compliance standpoint, this condition represents a direct violation of access lifecycle management requirements mandated across multiple regulatory frameworks. Regulators and auditors view terminated user accounts as a fundamental control failure, and the presence of such an account during an examination period will likely result in a formal finding, potential citation, or escalated scrutiny of the organization's broader access governance program. In a banking or healthcare context, this finding alone may trigger mandatory reporting obligations or examiner notification depending on jurisdictional requirements.

REMEDIATION:

The account for `mgarcia` must be disabled and deprovisioned immediately — within the same business day this finding is confirmed. The following steps should be executed without delay:

1. Disable the account in Active Directory or the identity provider to immediately revoke all authentication capabilities.
2. Revoke all active sessions, API tokens, OAuth grants, and VPN credentials associated with the account.
3. Suspend or remove all application-level entitlements tied to the account across Finance systems, ERP platforms, and data repositories.
4. Conduct a retrospective access log review covering the period from the employee's termination date to the present to determine whether any unauthorized access or activity occurred using this account.
5. Initiate a root cause analysis to identify why the offboarding process failed to deactivate this account, and remediate the process gap.
6. Implement automated account deactivation triggered by HR system termination events to prevent recurrence.
7. Document all remediation actions with timestamps for audit trail purposes.

FRAMEWORKS:

- NIST 800-53: AC-2 (Account Management) — Requires organizations to disable accounts immediately upon termination; IA-4 (Identifier Management) — Mandates revocation of identifiers for terminated individuals.
- PCI-DSS: Requirement 8.1.3 — Requires immediate revocation of access for terminated users; Requirement 8.2 — Mandates proper identification and authentication management throughout the account lifecycle.
- SOC 2: CC6.2 — Prior to issuing system credentials, logical access is registered and authorized; CC6.3 — Role-based access is reviewed and removed upon termination of employment.
- HIPAA: 45 CFR § 164.308(a)(3)(ii)(C) — Termination procedures requiring revocation of access to ePHI upon separation; 45 CFR § 164.312(a)(2)(i) — Unique user identification and access control management obligations.

FINDING: [HIGH] — rlee

RISK:

User account `rlee`, affiliated with the Finance department in the role of Contractor, has been identified as holding a Privileged access level. The assignment of privileged access to a contractor represents a significant violation of the principle of least privilege and introduces substantial risk to the organization's control environment.

Contractors are third-party personnel who, by definition, operate outside the organization's direct employment relationship and typically do not require — nor should they be granted — elevated system privileges to perform their defined scope of work. Privileged access may include administrative rights, the ability to modify system configurations, access to sensitive financial data in bulk, elevated database permissions, or the capacity to override system controls. The combination of contractor status and privileged access creates a particularly high-risk condition, as contractors may have concurrent access to competitor environments, limited accountability structures, and access that persists beyond the defined engagement period without adequate monitoring.

IMPACT:

The business risk associated with this finding is substantial. Privileged contractor accounts represent a common attack vector exploited in third-party breach scenarios. An adversary compromising `rlee`'s credentials would gain elevated access to Finance systems, potentially enabling unauthorized data extraction, manipulation of financial records, or lateral movement within the environment. From a compliance perspective, granting privileged access to contractors without documented business justification, formal approval, and compensating controls constitutes a control deficiency across multiple regulatory frameworks. In a banking environment, this may attract scrutiny from prudential regulators regarding third-party risk management. In a healthcare context, privileged contractor access to systems containing protected health information (PHI) without appropriate safeguards may constitute a reportable breach risk under HIPAA. Additionally, this finding may reflect broader weaknesses in the organization's vendor access governance and third-party risk management (TPRM) program.

REMEDIATION:

The following remediation actions should be implemented with urgency:

1. Immediately review and validate the business justification for `rlee`'s privileged access level. If no documented, approved justification exists, downgrade the account to Standard access without delay.
2. If privileged access is determined to be legitimately required for a specific, time-bound task, implement Just-in-Time (JIT) access provisioning so that elevated privileges are granted only for the duration of an approved session and automatically revoked upon completion.
3. Enforce Privileged Access Workstation (PAW) requirements or equivalent controls for any approved privileged contractor sessions.
4. Ensure all privileged sessions for contractor accounts are subject to session recording and monitoring via a Privileged Access Management (PAM) solution.
5. Validate that a current, signed Non-Disclosure Agreement (NDA) and Third-Party Access Agreement is on file for `rlee` with explicit provisions governing data handling.

6. Establish a quarterly contractor access review cadence to ensure privileged access is not retained beyond business need.

7. Implement a formal policy prohibiting assignment of privileged access to contractors without dual executive approval and documented exception management.

FRAMEWORKS:

- NIST 800-53: AC-6 (Least Privilege) — Requires that users, including contractors, are granted only the minimum access necessary to perform authorized functions; AC-2(7) (Role-Based Access Schemes) — Establishes requirements for privileged account management and monitoring; PS-7 (Third-Party Personnel Security) — Requires security controls governing access by third-party personnel.

- PCI-DSS: Requirement 7.1 — Limits access to system components to only those individuals whose job requires such access; Requirement 8.1.5 — Requires management of third-party remote access including enabling access only when needed and immediate deactivation when not in use.

- SOC 2: CC6.3 — Access is restricted to authorized and necessary entitlements; CC9.2 — Vendor and business partner risk management requirements including monitoring of third-party access.

- HIPAA: 45 CFR § 164.308(a)(4) — Information access management requiring minimum necessary access standards; 45 CFR § 164.308(b)(1) — Business associate management requirements governing contractor access to PHI-adjacent systems.

FINDING: [MEDIUM] — tjones

RISK:

User account `tjones`, associated with the HR department in the role of Manager, has been classified as a dormant account following detection of no recorded login activity for a period exceeding ninety (90) days. Dormant accounts represent a persistent and underappreciated access risk within identity governance programs. An account that is active but unused provides an available attack surface — if credentials are compromised through phishing, credential stuffing, or dark web exposure, an attacker can access the account without triggering activity-based detection controls, as any login would superficially resemble a reactivated legitimate session. The HR context of this account is particularly sensitive, as HR systems routinely contain highly confidential employee data including compensation records, performance documentation, personally identifiable information (PII), and in some cases, health-related employment records. A dormant manager-level account in this environment carries elevated inherent risk due to the likely breadth of data access associated with the Manager role.

IMPACT:

From a business standpoint, the existence of this dormant account indicates a potential gap in the organization's access recertification and lifecycle management processes. If `tjones` has transitioned roles, taken extended leave, or departed the organization through an informal process, their continued access to HR data constitutes an unnecessary exposure. Unauthorized access to HR records could result in employee data breaches, violations of privacy obligations, and significant reputational harm. From a compliance perspective, inactive accounts that are

not periodically reviewed and disabled represent a deficiency in access governance controls. Regulatory frameworks universally require that access be commensurate with current business need, and dormant accounts by definition fail this requirement. In a healthcare organization, dormant access to systems containing employee health accommodation records could implicate HIPAA administrative safeguard requirements.

REMEDIATION:

1. Immediately contact the account owner `tjones` and their direct supervisor to validate whether the account is still required for legitimate business purposes.
2. If the account owner confirms active need, require immediate re-authentication and credential rotation and document the verification.
3. If no active business need is confirmed, or if the account owner cannot be reached within five (5) business days, disable the account pending further investigation.
4. Conduct a review of `tjones`'s current access entitlements to confirm they remain appropriate for their current role and responsibilities.
5. Implement an automated dormancy detection and notification workflow that flags accounts with no login activity for 60 days and auto-disables accounts at the 90-day threshold, with appropriate manager notification.
6. Incorporate dormant account review into the organization's quarterly User Access Review (UAR) process.

FRAMEWORKS:

- NIST 800-53: AC-2(3) (Account Management — Disable Inactive Accounts) — Requires automatic disabling of accounts after a defined period of inactivity; AC-2 (Account Management) — Mandates periodic review of account necessity and appropriateness.

- PCI-DSS: Requirement 8.1.4 — Requires removal or disabling of inactive user accounts within 90 days; Requirement 8.2 — Mandates ongoing management of user identification and authentication.

- SOC 2: CC6.2 — Access provisioning is reviewed to ensure continued appropriateness; CC6.6 — Logical access controls include processes to identify and remediate inappropriate access.

- HIPAA: 45 CFR § 164.308(a)(3) — Workforce access management requiring review of access appropriateness; 45 CFR § 164.308(a)(5)(ii)(C) — Log-in monitoring requirements that support detection and response to dormant account conditions.

FINDING: [MEDIUM] — hkim

RISK:

User account `hkim`, affiliated with the Finance department in the role of Contractor, has been flagged as a dormant account with no recorded login activity for a period exceeding ninety (90) days. This finding combines two compounding risk factors: the account belongs to a contractor — a third-party individual with inherently elevated risk characteristics — and the account has been inactive for an extended period, suggesting that the associated engagement or task may have concluded without proper offboarding and access revocation being performed. Contractor accounts are frequently provisioned for specific, time-limited project engagements and are particularly susceptible to orphaning when project completion is not systematically linked to access deprovisioning workflows. An orphaned contractor account in the Finance department, even at a Standard access level, may retain access to financial data, reporting systems, or shared drives containing sensitive organizational information.

IMPACT:

The presence of a dormant contractor account in the Finance department indicates a likely deficiency in the organization's third-party access lifecycle management controls. If the contractor engagement has concluded, this account should have been deprovisioned at project closeout. The continued existence of this access pathway creates unnecessary risk of unauthorized access to financial data, particularly if the contractor's credentials have been compromised or shared. From a regulatory standpoint, this finding may indicate systemic weaknesses in the vendor access governance program that extend beyond this individual account. Auditors reviewing a pattern of dormant contractor accounts will likely escalate their assessment of the organization's third-party risk management maturity. In environments subject to PCI-DSS, dormant contractor access within the cardholder data environment (CDE) or systems adjacent to it is treated with particular severity.

REMEDIATION:

1. Immediately verify the current engagement status of contractor `hkim` with the sponsoring business unit and vendor management office.
2. If the contractor engagement has concluded or the account is no longer required, disable and fully deprovision the account immediately, including revocation of all application entitlements and system credentials.
3. If the engagement is ongoing and access is legitimately required, enforce immediate credential rotation and require the contractor to verify their identity before access is reinstated.
4. Review all contractor account access within the Finance department as part of an emergency contractor access audit to identify additional orphaned or dormant contractor accounts.
5. Implement a contractor access expiration policy requiring all contractor accounts to carry a hard expiration date tied to the documented contract end date, with mandatory renewal approval required for any extension.
6. Integrate contractor offboarding into the vendor contract management lifecycle to ensure access deprovisioning is a required step at contract conclusion.
7. Require quarterly attestation from business unit managers confirming the continued necessity of all active contractor accounts under their sponsorship.

FRAMEWORKS:

- NIST 800-53: AC-2 (Account Management) — Requires monitoring of accounts and removal of access when no longer required; AC-2(3) — Mandates disabling of inactive accounts; PS-7 (Third-Party Personnel Security) — Requires formal processes for managing contractor access including termination procedures.

- PCI-DSS: Requirement 8.1.4 — Requires disabling of inactive accounts within 90 days; Requirement 8.1.5 — Specifically governs third-party remote access management including enabling access only when needed; Requirement 12.8 — Mandates policies and procedures for managing third-party service providers with access to system components.
- SOC 2: CC6.2 — Logical access provisioning includes review of ongoing access appropriateness; CC9.2 — Vendor risk management controls require monitoring of third-party access and enforcement of access termination upon engagement conclusion.
- HIPAA: 45 CFR § 164.308(a)(3)(ii)(C) — Termination procedures applicable to workforce members including contractors; 45 CFR § 164.308(b) — Business associate oversight requirements governing contractor access controls and obligations.

Summary Risk Matrix

Severity	Username	Department	Finding	Status
----------	----------	------------	---------	--------

---	---	---	---	---
-----	-----	-----	-----	-----

■ Critical	mgarcia	Finance	Terminated user — active account	Immediate Action Required
------------	---------	---------	----------------------------------	---------------------------

■ High	rlee	Finance	Contractor with privileged access	Urgent Review Required
--------	------	---------	-----------------------------------	------------------------

■ Medium	tjones	HR	Dormant account — 90+ days	Review & Remediate
----------	--------	----	----------------------------	--------------------

■ Medium	hkim	Finance	Dormant contractor — 90+ days	Review & Remediate
----------	------	---------	-------------------------------	--------------------

Auditor Recommendations — Systemic Observations

Beyond the individual findings documented above, the auditor notes that the concentration of access control deficiencies within the Finance department (three of four findings) warrants an expanded access review of all Finance department accounts, including a full entitlement review and recertification exercise. Additionally, the presence of both a terminated user account and multiple dormant accounts suggests potential systemic gaps in the following program areas:

- HR-to-IT offboarding integration: Termination events are not reliably triggering access revocation workflows.
- Contractor lifecycle management: No automated expiration or dormancy controls appear to be enforced for third-party accounts.